Registro dei rischi

Ambiente operativo:

La banca si trova in una zona costiera con un basso tasso di criminalità. Molte persone e molti sistemi trattano i dati della banca: 100 dipendenti in sede e 20 da remoto. La clientela comprende 2.000 conti privati e 200 conti aziendali. I servizi della banca sono promossi da una squadra sportiva professionistica e da dieci attività locali della comunità. Ci sono normative finanziarie severe che obbligano la banca a proteggere dati e fondi, per esempio avendo ogni giorno abbastanza liquidità per rispettare i requisiti della Federal Reserve.

Bene	Rischi	Descrizione	Probabilità	Gravità	Priorità
Fondi	Compromissione dell'email aziendale	*Un dipendente viene ingannato e condivide informazioni riservate.*	3	2	6
	Database utenti compromesso	*I dati dei clienti sono cifrati male.*	2	3	6
	Fuga di registri finanziari	*Un server di database con i dati di backup è accessibile pubblicamente.*	3	3	9
	Furto	*La cassaforte della banca viene lasciata aperta.*	1	3	3
	Interruzione della catena di fornitura	*Ritardi nelle consegne dovuti a disastri naturali.*	2	1	2
Note	*Come sono possibili eventi di sicurezza, considerando i rischi che il bene affronta nel suo ambiente operativo?* *La compromissione dell'email aziendale è il rischio più probabile perché la banca ha 120 persone e molte lavorano da remoto, e basta una sola email convincente. Il danno è moderato se viene scoperta presto, ma può arrivare ai fondi. I dati dei clienti cifrati male sono un problema serio con 2.200 conti e normative finanziarie severe, quindi l'impatto è alto anche se un attacco non è certo. Un server pubblico con i backup è la priorità massima: è facile da trovare ed espone registri finanziari completi, quindi probabilità e gravità sono entrambe alte. Il furto da una cassaforte aperta è poco probabile in una zona con poca criminalità, ma la perdita sarebbe grande, ed è per questo che servono comunque una serratura e una regola. I ritardi di consegna per le tempeste sono possibili sulla costa, ma danneggiano le operazioni più di quanto danneggino la sicurezza dei fondi, quindi la priorità è bassa.*				

Bene: il bene a rischio di essere danneggiato, distrutto o rubato.
Rischi: un rischio potenziale per i sistemi informativi e i dati dell'organizzazione.
Descrizione: una vulnerabilità che può portare a un incidente di sicurezza.

Probabilità: punteggio da 1 a 3 sulle possibilità che una vulnerabilità venga sfruttata. 1 vuol dire probabilità bassa, 2 probabilità moderata e 3 probabilità alta.
Gravità: punteggio da 1 a 3 sul danno potenziale che la minaccia causerebbe all'azienda. 1 vuol dire impatto lieve, 2 impatto moderato e 3 impatto grave.
Priorità: quanto in fretta va affrontato un rischio per evitare l'incidente potenziale. Per calcolare il punteggio complessivo si usa questa formula: probabilità x gravità = rischio.

Esempio di matrice dei rischi

	Bassa 1	Moderata 2	Catastrofica 3
Certa 3	3	6	9
Probabile 2	2	4	6
Rara 1	1	2	3